AEGISAI ENTERPRISE EDITION

TECHNICAL DOCUMENTATION SUITE

Administration & Operations Manual

DevSecOps, Secrets Governance, Quota Management & Observability

Platform Version:	**2.5.0 Enterprise Edition**
Compliance Scope:	**OWASP AISVS v1.0, ISO/IEC 42001:2023, Google Cloud Security**
License:	**Apache License 2.0 (Open Source)**

AEGIS AI ASSURANCE PLATFORM

Administration and Operations Manual (DevSecOps Guide)

Version: 2.5.0 Enterprise (2026 Edition)

Classification: Operational Technical Guide / General Use

Scope: Platform Governance, Key Management, Observability, and Operations

---

1. Administrator Profile and Responsibilities

The AegisAI Administrator is responsible for:

1. Custodying and rotating system master credentials (`ADMIN_API_TOKEN` and `GEMINI_API_KEY`).
2. Monitoring quota, latency, and inference telemetry for the Google Gemini API.
3. Managing the custom regulatory frameworks catalog (BYOF module) and authorizing the publication or deprecation of organizational regulations.
4. Maintaining the integrity and availability of the dual-storage layer (local JSON files and Cloud Firestore database).
5. Handling operational incidents and ensuring compliance with Service Level Agreements (SLAs).

---

2. Identity Management and Access Control

2.1 Layered Zero-Trust Authentication Scheme (`C05.3`)

AegisAI implements four complementary Zero-Trust authentication mechanisms:

Access Level	Mechanism	Variable / Header	Operational Scope
Perimeter Edge	Cloud Identity-Aware Proxy (IAP)	`x-goog-authenticated-user-email`	Enforces `--no-allow-unauthenticated` at the Google Cloud edge before requests reach the container (`C04.3`).
Auditor Session	Firebase Auth ID Token (JWT)	`Authorization: Bearer <idToken>`	Verified via `getAdminAuth().verifyIdToken()` in `extractUserSecurityContext(req)` to bind tenant/owner context (`C05.3`, `C05.4`, `C08.1`).
Web Administration	Secret Manager Master Token	`x-admin-token` header	Verified in constant time via `crypto.timingSafeEqual` (`timingSafeTokenMatch`) for `/api/admin/*` and framework lifecycle management.
CI/CD Automation	Scoped Service API Key	`x-api-key` header	Constant-time verified (`crypto.timingSafeEqual`) or Firestore-validated key for `/api/v1/audits`.

2.2 Constant-Time Administrative Authentication Middleware (`C05.3`)

To eliminate byte-by-byte timing side-channel attacks, `/api/admin/*` and `/api/v1/audits` never use standard string equality (`===`). Instead, `server.ts` hashes both inputs with SHA-256 into fixed 32-byte buffers and compares them in constant time using `crypto.timingSafeEqual` :

```
function timingSafeTokenMatch(provided: string | null | undefined, configured: string | null | undef
  if (!provided || !configured) return false;
  const hashProvided = crypto.createHash('sha256').update(String(provided), 'utf8').digest();
  const hashConfigured = crypto.createHash('sha256').update(String(configured), 'utf8').digest();
  return crypto.timingSafeEqual(hashProvided, hashConfigured) && provided.length === configured.leng
}

const authenticateAdmin = (req: express.Request, res: express.Response, next: express.NextFunction)
  const configuredToken = process.env.ADMIN_API_TOKEN;
  const providedToken = (req.headers['x-admin-token'] as string) ||
    (req.headers.authorization?.startsWith('Bearer ') ? req.headers.authorization.split(' ')[1] : nu

  if (timingSafeTokenMatch(providedToken, configuredToken)) {
    return next();
  }
  return res.status(401).json({ error: 'Unauthorized access: Invalid or missing administration token
};
```

3. Multi-Model Artificial Intelligence Engine Configuration and Monitoring

3.1 Decoupled Multi-Provider Support

AegisAI features a universal decoupled inference engine that allows operating with both Google Cloud Vertex AI / Gemini models and external providers/routers compatible with the OpenAI specification (`/v1/chat/completions`):

- **Google Cloud Vertex AI (Default Enterprise Backend):** Native models (`gemini-3.8-flash` , `gemini-3.1-flash-lite` , `gemini-3.7-flash`) via the `@google/genai` SDK using Application Default Credentials (`aegis-runner-sa`) with `responseLogprobs: false` (`C11.4`).
- **OpenRouter / Direct OpenAI / Local Proxy:** Validated against SSRF and private IP ranges via `validateOutboundEndpoint` (`C04.3`) before dispatching HTTPS requests.

3.2 Secret Manager & Immutable Runtime Configuration (`C04.1`, `C05.2`)

In production on Google Cloud Run, secrets are injected from **Google Cloud Secret Manager** (`--set-secrets="ADMIN_API_TOKEN=aegis-admin-token:latest"`) and the `/app` container filesystem is mounted strictly read-only (`RUN chmod -R a-w /app`).

```
# Production Environment Variables (Cloud Run)
NODE_ENV="production"
PORT=8080
PROJECT_ID="your-project-id"
GOOGLE_CLOUD_LOCATION="us-central1"
GOOGLE_GENAI_USE_VERTEXAI="true"
FIRESTORE_DATABASE_ID="aegis-ai-db"
```

Dynamic administrative overrides are persisted to **Cloud Firestore (`system_config/admin_settings`)** and cached in the isolated ephemeral directory `/tmp/aegis-runtime-cache/admin-settings.json` (never mutating `/app/config`):

```
{
  "provider": "gemini",
  "preferredModel": "gemini-3.8-flash",
  "temperature": 0.0,
  "maxTokens": 8192,
  "fallbackModel": "gemini-3.1-flash-lite",
  "updatedAt": "2026-10-25T23:00:00.000Z"
}
```

3.3 Inference Control and Governance Parameters

1. **Temperature:** Configurable from 0.0 to 1.0 (Default: `0.0` to ensure deterministic and scientifically reproducible compliance evaluations).
2. **Output Token Limit (`maxTokens`):** Maximum generation limit per evaluation block (Default: `8192`).
3. **Logprob Suppression (`responseLogprobs: false`):** Hardcoded to prevent model extraction and distillation attacks (`C11.4`).
4. **Fallback Model (`fallbackModel`):** Secondary model that takes over the load if the primary model suffers temporary quota exhaustion (HTTP 429/503).

3.4 Real-Time Connectivity Diagnostics and Hot-Reload

From the web administration interface or via the REST API, the administrator can validate the inference channel by measuring **latency in milliseconds (ms)**:

```
curl -X POST https://aegis-ai-xxxxx.a.run.app/api/admin/test-connection \
  -H "Content-Type: application/json" \
  -H "x-admin-token: YOUR_ADMIN_API_TOKEN" \
  -d '{"provider": "gemini", "model": "gemini-3.8-flash"}'
```

3.5 LLM Engine Automated Test Suite

To certify the correct operation of the providers and security controls:

```
npm run test:llm
npm run test:security
```

---

4. Immutable Storage Management, SHA-256 Integrity, and Compensating Saga (`C01.4`, `C04.1`, `C08.1`, `C09.4`)

4.1 Read-Only Baseline + Ephemeral Cache & Cloud Firestore Architecture

1. **Immutable Normative Baselines (`/app/config/frameworks/*.json` & `*.md`):** Sealed inside the read-only container image (`chmod -R a-w /app`) and verified at startup by `verifyNormativeSnapshotsIntegrity()` against SHA-256 hashes in `config/frameworks/integrity-manifest.json` (`C01.4`).
2. **Cloud Firestore Native (`aegis-ai-db`):** Authoritative multi-instance store for `audits` , `custom_frameworks` , `apiKeys` , `auditJobs` , and `system_config/admin_settings` .
3. **Ephemeral Runtime Cache (`/tmp/aegis-runtime-cache`):** Isolated writable scratch space for runtime caching (`C04.1`).

4. **Pre-Retrieval Tenant ACL Filtering (`C08.1`):** `listCustomFrameworks(callerDomain)` enforces tenant domain isolation prior to loading custom frameworks into the evaluation prompt.
5. **Compensating Saga Coordinator (`C09.4`):** Multi-step framework ingestion and audit persistence run inside `runCompensatingSaga()` , automatically rolling back partial cache/Firestore writes if any step fails.

4.2 Framework Catalog Backups

```
mkdir -p /backups/aegisai/$(date +%Y%m%d)
cp -r /app/config/frameworks/*.json /backups/aegisai/$(date +%Y%m%d)/
```

4.3 Procedure for Deleting a Custom Regulatory Framework

```
curl -X DELETE https://aegis-ai-xxxxx.a.run.app/api/frameworks/fw-id-to-delete \
  -H "x-admin-token: YOUR_ADMIN_API_TOKEN"
```

---

5. Telemetry, Active Security Defense, and Observability (`C02.10`, `C08.4`, `C10.1`, `C11.1`, `C12.2`)

5.1 Per-Audit Metrics & Continuous Grounding Telemetry (`C08.4` / ISO `Clause 9.1`)

Each processed audit records `modelUsed` , `latencyMs` , `promptTokens` , and `completionTokens` , and updates the live AIMS telemetry aggregator (`recordAimsEvaluationMetrics`). Administrators can inspect real-time grounding faithfulness (target SLO $\ge 95.0\%$), determinism index (100%), and active defense counters via:

```
curl -s https://aegis-ai-xxxxx.a.run.app/api/admin/aims-telemetry \
  -H "x-admin-token: YOUR_ADMIN_API_TOKEN"
```

5.2 Security Posture & MCP Supply-Chain Verification Endpoints (`C01.4`, `C10.1`)

- **Security Posture Check (`GET /api/security/posture`):** Returns live verification status of SHA-256 normative integrity (`C01.4`), Anti-DoW rate/token quotas (`C11.1`), SSRF protection (`C04.3`), and DNS rebinding defenses (`C10.5`).
- **MCP Signed Manifest Verification (`POST /api/mcp/verify`):** Validates HMAC-SHA256 cryptographic signatures and tool SHA-256 digests (`verifyMcpManifestSignature`) before enabling any external Model Context Protocol (MCP) connector (`C10.1`).

5.3 Log Sanitization and Real-Time Security Alerting (`C12.2`)

`redactSensitiveStrings` masks all API keys (`AIzaSy...` , `sk-...`) and Bearer tokens before log emission. Whenever `inspectPromptAndTrackSession` detects a prompt injection / crescendo attack (`C02.10`), `validateOutboundEndpoint` blocks an SSRF attempt (`C04.3`), or `acquireAntiDoWQuota` rejects a Denial-of-Wallet spike (`C11.1`), `emitSecurityAlert` writes a structured `[AEGIS_SECURITY_ALERT]` JSON entry to Google Cloud Logging (`severity: WARNING | ERROR | CRITICAL`) and dispatches an optional webhook to the corporate SIEM (`SECURITY_ALERT_WEBHOOK_URL`).

---

6. Standard Operating Procedures (SOPs)

SOP-01: Secret Manager Admin Token & Credential Rotation (`C05.3`)

1. Add a new secret version in Google Cloud Secret Manager:

```
openssl rand -hex 32 | gcloud secrets versions add aegis-admin-token --data-file=- --project="
```

2. Update the Cloud Run service to mount the latest secret version:

```
gcloud run services update aegis-ai --region="$REGION" --update-secrets="ADMIN_API_TOKEN=aegis
```

SOP-02: Anti-DoW Quota Exceeded / HTTP 429 Incident Response (`C11.1`)

1. Inspect `GET /api/admin/aims-telemetry` (`rateLimitRejections`) and Cloud Logging for `[AEGIS_SECURITY_ALERT]` events with category `ANTI_DOW_RATE_LIMIT`, `ANTI_DOW_CONCURRENCY`, or `ANTI_DOW_TOKEN_BUDGET`.
2. Verify whether the traffic originates from a legitimate batch CI/CD pipeline or an abusive client; adjust `AEGIS_RATE_LIMIT_PER_MIN` (default `10`), `AEGIS_MAX_CONCURRENT_EVALS` (default `2`), or `AEGIS_MAX_TOKENS_PER_HOUR` (default `500000`) if authorized by the CISO.